INSPECCO × KRIPTARIUM

Safety 4.0 Bootcamp

Laboratuvar Föyleri — Genel Sürüm · Şişeleme Hattı

Tüm laboratuvarlar gün boyu gelişen tek bir örnek makine — jenerik şişeleme hattı — üzerinde işlenir.

LAB 1 · Safety Architecture	Çıktı: Safety Function Map
LAB 2 · IEC 62443 Mini Workshop	Çıktı: Zone / Conduit Diagram
LAB 3 · Threat & Risk + Risk Matrix	Çıktı: Risk Register
LAB 4 · Secure Remote Access	Çıktı: Secure Architecture
LAB 5 · SBOM / CVE / Patch	Çıktı: Vulnerability Decision
LAB 6 · CRA Incident Simulation	Çıktı: Incident Workflow
LAB 7 · AI Safety Challenge	Çıktı: AI Fail-Safe Decision

Bu föyler bir eğitim çıktısıdır; resmî denetim, uygunluk değerlendirmesi veya belgelendirme değildir ve CE/mevzuat uygunluğu garantisi vermez. Doldurduğunuz föyler gün sonunda Machine Starter Pack'inizi oluşturur ve Safety 4.0 Workspace'te yaşamaya devam eder.

LABORATUVAR 1 · GENEL SÜRÜM · Şişeleme Hattı

Safety Architecture

Çıktı: Safety Function Map

Ad Soyad | Grup | Tarih

Kavram: Emniyet fonksiyonu, insanı koruyan fonksiyondur ve **ayrı bir safety yolunda** yaşar (E-stop → Safety PLC → STO). Gerekli güvenilirliği (PLr/SIL) riskle orantılıdır — ve bu güvenilirlik, **dijital bir konfigürasyona** bağlıdır.



Görev — sırayla cevaplayın

1 Bu makinede tehlike nedir? İnsan neyden zarar görür?

Hareketli ve enerjili parçalar: konveyör, dolum/kapatma karuseli, paletleyici robot, pnömatik basınç. Operatör bakım, sıkışma giderme veya temizlikte makineye girer; beklenmedik hareketle ezilme, sıkışma ve cam şişe kırığıyla kesilme riski yaşar.

2 Safety function (emniyet fonksiyonu) hangisidir?

Tehlikeli bölgede güvenli durdurma: E-stop ve ışık perdesi / koruyucu kapak açıldığında E-stop/Işık perdesi → Safety PLC → STO/Kontaktör → Safe State zinciriyle tehlikeli hareketin kesilmesi.

3 Safety-related control system nerede? Şemada işaretleyin.

Safety yolunun tamamı: E-stop/Işık perdesi (girdi) + Safety PLC (mantık) + STO/Kontaktör (çıktı). Şemada alt satırdaki bu üç kutu birlikte çevrelenir; üstteki Sensör → PLC → Aktüatör hattı bunun dışındadır.

4 Normal PLC ile Safety PLC farkı nedir?

Normal PLC üretimi yönetir (hız, sıra, tarif); arızası üretim kaybıdır. Safety PLC insanı korur: çift kanallı, sürekli kendini diagnoz eder, SIL/PLr ile doğrulanmıştır ve arızada güvenli duruma gider; programı da ayrı korunur ve doğrulanır.

5 PLr / SIL neden var? Bu fonksiyon için neden önemli?

PLr/SIL, emniyet fonksiyonunun tehlikeli arıza olasılığını riske göre sınırlar: risk yüksekse güvenilirlik de yüksek olmalı. E-stop/STO insan hayatını korur, hatası ölüm/yaralanma demektir; ayrıca bu güvenilirlik doğru konfigürasyona (parametre, yazılım) bağlıdır.

6 Safe state (güvenli durum) nedir?

Makinenin insan için tehlikesiz olduğu durum: tehlikeli hareket ve enerji kesilmiş (STO), kontaktör açık, yeniden başlatma yalnızca bilinçli reset ile olur. Arıza, enerji veya komut kaybında sistemin düştüğü yerdir (fail-safe).

7 Safety function hangi dijital bağımlılıklara sahip?

Safety PLC programı/konfigürasyonu ve parametreleri (mühendislik istasyonu, IPC), firmware ve yazılım kütüphaneleri, safety haberleşme ağı ve geçitleri, uzak servis erişimi ve hesapları, güncelleme/yama süreci, yedek ve doğrulama dosyaları.

8 Siber müdahale hangi noktadan bu fonksiyonu bozar?

Şemadaki 'dijital kesişim noktası'ndan: IPC / Uzak Erişim → Safety PLC bağlantısı. Çalıntı servis hesabı veya kötü bir güncelleme ile Safety PLC konfigürasyonu değişir; STO/ışık perdesi fonksiyonu fiilen devre dışı kalır. Normal PLC'ye girişin safety'ye yayılması da aynı yoldur.

Bu föyün çıktısı **Safety Function Map** → Evidence Pack **EP 03 Safety Functions** başlığına oturur.

LABORATUVAR 2 · GENEL SÜRÜM · Şişeleme Hattı

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad | Grup | Tarih

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi

PLC · HMI · Robot kontrolörü · **Safety PLC** · SCADA istemcisi · Mühendislik istasyonu · Uzak servis erişimi · Ofis ağı (ERP/e-posta)

1. Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

Üretim bölgesi: PLC, HMI, Robot kontrolörü, SCADA istemcisi. Emniyet bölgesi: Safety PLC (tek başına). Mühendislik/DMZ bölgesi: Mühendislik istasyonu ve Uzak servis erişimi (jump server üzerinden). Kurumsal bölge: Ofis ağı (ERP/e-posta). Aynı kritiklik ve güven düzeyindeki varlıklar bir arada tutulur.

2. Safety PLC'yi hangi bölgeye koydunuz — neden?

Safety PLC ayrı Emniyet bölgesinde: insan güvenliği en yüksek kritikliktir, bu yüzden üretim ağından, mühendislik ve uzak erişimden izole edilir. Ona tek bir kontrollü, izlenen geçitle ulaşılır; ofis ağı ve uzak erişimle doğrudan bağlantısı yoktur.

3. Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

Ofis ↔ DMZ, DMZ ↔ Üretim ve Üretim ↔ Emniyet geçişleri. Her geçişte: güvenlik duvarıyla yalnızca izinli protokol/IP/yön (varsayılan reddet), MFA'lı kişisel kimlik, jump server, oturum kaydı/log. Emniyet geçişinde yalnız sınırlı tanı; konfigürasyon yazımı yok.

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	Jump server: tek ve denetlenen giriş noktası; doğrudan erişim kontrolsüz bir kapıdır, oturum izlenip kaydedilir.
Tünel?	Açık / VPN	VPN: şifreli, kimliği doğrulanmış kanal; açık/korumasız bağlantı dışarıdan sızmaya izin verir.
Kimlik?	Parola / MFA	MFA: çalınan parola tek başına yetmez; servis hesabı ihlali riskini düşürür.
Hesap?	Paylaşılan / Kişisel	Kişisel: kimin ne yaptığı izlenebilir, yetki kişiye göre verilir; paylaşılan hesapta sorumluluk kaybolur.
Kayıt?	Yok / Tam oturum kaydı	Tam oturum kaydı: olay incelemesi, kanıt ve denetim izi için şart (kayıt yoksa kök neden bulunamaz).
Zamanlama?	Sürekli açık / Varsayılan kapalı	Varsayılan kapalı: yalnızca onaylı bakım penceresinde, süreli açılır; saldırı yüzeyi küçülür.

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.

LABORATUVAR 3 · GENEL SÜRÜM · Şişeleme Hattı

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad | Grup | Tarih

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç**. Skor = L × S × E (her biri 1–3). **Kural:** S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır.

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim→kapı→zincir→fiziksel sonuç)	L	S	E	Skor	Öncelik
Saldırgan: çalıntı servis hesabı → uzak erişim → PLC/safety konfigürasyonunu değiştirir → STO/ışık perdesi etkisiz → operatör ezilir/yaralanır.	**2**	**3**	**3**	**18**	**Kritik**
Saldırgan: kötü amaçlı USB/e-posta → mühendislik istasyonu → PLC programı bozulur → konveyör/robot beklenmedik hareket → bakımdaki personel yaralanır.	**2**	**3**	**1**	**6**	**Orta S=3: öne alındı**
Saldırgan: ofis ağından yanal hareket → SCADA/HMI → dolum parametreleri değişir → kalite hatası, ürün kaybı, plansız duruş.	**3**	**1**	**2**	**6**	**Orta**

Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3

1. En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?

   Senaryo 1 (skor 18, Kritik): çalıntı servis hesabıyla safety konfigürasyonu değişirse koruma devre dışı kalır ve operatör doğrudan fiziksel zarar görür (S=3, sık maruziyet E=3); erişim yolu da mevcuttur.

2. S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?

   Evet, Senaryo 2: S=3 ama E=1 olduğu için skor 6 (Orta) kaldı. Risk Register'da 'S=3' bayrağıyla işaretler, skordan bağımsız olarak listenin üstüne alır ve emniyet bulgusu olarak ayrı raporlarım; kapanana kadar izlenir.

Altın kural: Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — bir adım daha gidin: bu, hattaki insana ne yapar?

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.

LABORATUVAR 4 · GENEL SÜRÜM · Şişeleme Hattı

Secure Remote Access

Çıktı: Secure Architecture

Ad Soyad	Grup	Tarih

Kavram: İki katman, ikisi de şart: **erişim güvenliği** (girişi zorlaştır: ara nokta, VPN, MFA, kişisel hesap, kayıt, varsayılan kapalı) + **emniyet bağımsızlığı** (girse bile insan korunur).

Görev A — mevcut → hedef

MEVCUT (çizin/yazın)

Servis firması internetten PLC'ye doğrudan bağlanıyor; bağlantı sürekli açık, açık/korumasız tünel, tek paylaşılan parola, oturum kaydı yok. IPC/uzak erişim ile Safety PLC aynı ağda, aralarında bölge ayrımı yok.

HEDEF (beş ilkeyle yeniden tasarlayın)

Servis firması → VPN → jump server (MFA, kişisel hesap) → yalnızca Üretim bölgesi; tam oturum kaydı; erişim varsayılan kapalı, onaylı bakım penceresinde süreli açılır. Safety PLC ayrı bölgede, uzak erişimden izole.

Görev B — functional safety köprüsü

1. Saldırgan tüm önlemlere rağmen içeri girerse: emniyet fonksiyonu etkilenir mi? Neden?

   Mevcut tasarımda evet: Safety PLC konfigürasyonuna ağ/IPC üzerinden ulaşılabiliyorsa saldırgan STO ve ışık perdesini etkisiz kılabilir.

   Hedefte etkilenmemeli: safety ayrı yolda ve uzak erişim/ağ üzerinden değiştirilemez, ihlalde de insan korunur.

2. Emniyet fonksiyonunun kontrol sisteminden bağımsız çalışması için GEREKSİNİMİ yazın (çözümü değil).

   Emniyet fonksiyonu, kontrol sistemi ve uzak erişim ele geçirilse de çalışmalı: ayrı donanım ve kablolama, safety konfigürasyonuna ağdan yazma yok (yalnız yerel, yetkili ve fiziksel onayla), komut/enerji kaybında güvenli duruma geçiş, değişikliklerin bütünlük kontrolü ve kaydı.

Tarafsızlık notu: Bu föy çözüm tasarlatmaz; gereksinimi tanımlatır. Tasarım kararı firmanızındır.

Bu föyün çıktısı **Secure Architecture** → Evidence Pack **EP 02 + EP 06** başlığına oturur.

LABORATUVAR 5 · GENEL SÜRÜM · Şişeleme Hattı

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad | Grup | Tarih

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   Üç şartı kontrol ederim: (1) bileşen var: SBOM'da Component X (PLC firmware) kayıtlı; (2) sürüm 2.4 CVE'nin etkilenen aralığında mı (bülten); (3) açık ulaşılabilir mi (ağdan/uzak erişimden). Üçü evetse etkiliyiz; biri hayırsa acil değil, kayda alınır.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Hayır. Önce üç şartla gerçek etkiyi doğrularım; kontrolsüz duruş da risktir. Hemen geçici önlem (erişimi kısıtla/kapat), yama için planlı duruş penceresi. Aktif istismar veya safety etkisi varsa hattı güvenli şekilde durdururum.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

   Önce test: üretimden ayrı test PLC'sinde veya yedek/dijital ikiz ortamında denerim. Yedek ve geri dönüş planıyla, bakım penceresinde aşamalı uygularım; doğrudan üretime yama uygulamam.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   Evet etkileyebilir: firmware/kütüphane safety fonksiyonunu veya konfigürasyonunu değiştirebilir. Anlamak için üretici sürüm notları, sağlama (hash/imza) ve konfigürasyon karşılaştırması, değişiklik etki analizi; etkileniyorsa safety fonksiyon testi/yeniden doğrulama.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

   Erişimi kapatıp sınırlarım: ağ segmentasyonu ve güvenlik duvarı kuralı, uzak erişim varsayılan kapalı (jump server/VPN/MFA), ilgili servis/portu devre dışı bırakma, izleme ve alarm, USB/yazma kısıtı. Geçici, kayıtlı ve yama olana kadar süreli.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.

LABORATUVAR 6 · GENEL SÜRÜM · Şişeleme Hattı

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad	Grup	Tarih

Senaryo: Saat **10:15**. Servis hesabında yetkisiz erişim tespit edildi. PLC konfigürasyonu değişmiş olabilir. Makine hâlâ çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eyleminiz?

   Vardiya amiri/emniyet sorumlusu, OT/IT güvenlik sorumlusu ve yönetimi ararım. (1) Makineyi güvenli duruma alır, insanı korurum; (2) servis hesabını/uzak erişimi izole ederim; (3) kanıtı korurum (log, ekran görüntüsü, yedek), PLC'yi resetlemem.

2. **İlk 2 saat:** Emniyet güvende mi? Neyi korursunuz (kanıt!)? Hangi hesap kapatılır?

   Safety fonksiyonunu (E-stop, ışık perdesi) test eder, Safety PLC konfigürasyonunu bilinen iyi yedekle karşılaştırırım. Korunacak kanıt: PLC/mühendislik, VPN ve güvenlik duvarı logları, servis hesabı kayıtları, zaman damgalı yedekler. Servis hesabı kapatılır, parolalar yenilenir.

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?

   Olay özeti (ne, ne zaman, nasıl fark edildi), etkilenen hat/ürün ve sürümler, istismar şüphesi, alınan ilk önlemler, iletişim kişisi. Eksik bilgi sonradan tamamlanır.

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem — kim ne yapıyor?

   Kök neden (hesap nasıl ele geçti), etki (PLC/safety değişti mi, üretim ve güvenlik), alınan önlem. OT/güvenlik kök nedeni, bakım/emniyet etkiyi ve doğrulamayı, yönetim/uyum bildirimi yapar.

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?

   Servis hesabı, VPN/jump server, güvenlik duvarı ve PLC/mühendislik logları; PLC konfigürasyonu önce/sonra yedek ve hash'leri; oturum kayıtları; bakım/değişiklik kayıtları; zaman çizelgesi ve alınan aksiyonlar (kanıt zinciri bozulmadan).

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.

LABORATUVAR 7 · GENEL SÜRÜM · Şişeleme Hattı

AI Safety Challenge

Çıktı: AI Fail-Safe Decision

Ad Soyad	Grup	Tarih

Kavram — Prediction ≠ Safety: Yapay zekâ bir karar üretir; güvenliği garanti eden mimari YZ'nin **dışında** tanımlanmalıdır.
Araçlar: fail-safe · human override · monitoring · confidence threshold · fallback.

Kamera → YZ Modeli → OK / RED → Parametre → Robot

Görev — üç başarısızlıkta güvenli davranış

1. **Model yanlış sınıflandırdı:** Kusurlu parçaya OK verdi. Sistem ne yapmalı? İkinci kontrol / insan onayı var mı?

   YZ kararı tek başına yetmez: bağımsız ikinci kontrol (ikinci sensör/kural tabanlı ölçüm) ve insan onayı olmalı. Hatalı OK yakalanırsa parça ayrılır, hat güvenli durumda tutulur, kayıt alınır; güvenlik mimarisi YZ'nin dışında tanımlıdır.

2. **Girdi manipüle edildi:** Kamera verisi bozuk/sahte. Nasıl fark edilir? Şüpheli girdide ne yapılır?

   Görüntü kalite/tutarlılık kontrolü, sensör sağlığı ve zaman damgası, ikinci sensörle çapraz kontrol, anomali izleme (monitoring) ile fark edilir. Şüpheli girdide model sonucu kullanılmaz: güvenli duruma (dur/reddet/fallback) geçilir, alarm verilir, insan devralır (human override).

3. **Confidence düştü:** Model "emin değilim" diyor. Eşik ne olmalı? Altında: dur / insana sor / fallback?

   Eşik riske göre ve doğrulanarak belirlenir (örn. %95 ve üzeri). Altında otomatik karar yok: önce fallback (parçayı reddet/ikinci kontrole al); tekrarlanırsa hat durur ve insana sorulur (human override). Confidence sürekli izlenir.

Karar tablosu — AI Fail-Safe Decision

Başarısızlık	Tanımladığınız güvenli davranış (hangi kavramla?)
Model yanlış sınıflandırdı	Bağımsız ikinci kontrol + insan onayı; şüpheli parça reddedilir (fail-safe, human override).
Girdi manipüle edildi	Girdi doğrulama + monitoring; şüpheli veride modeli kullanma, dur/fallback (fail-safe).
Confidence düştü	Confidence threshold: eşik altında dur / insana sor / fallback (human override).

Bu föyün çıktısı **AI Fail-Safe Decision** → Evidence Pack **EP 03 + EP 15** başlığına oturur.